PRIVACY PROCESS

SOP-004 | Issued under POL-004 — Privacy Policy

Document ID: SOP-004
Version: 1.0 — DRAFT
Parent Policy: POL-004 — Privacy Policy
Parent Framework: IMF-001 — Information Management Framework
Classification: Internal Use
Owner: Data Protection Officer
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Privacy Process
Document ID	SOP-004
Version	1.0 — DRAFT
Status	Draft for Review
Parent Policy	POL-004 — Privacy Policy
Parent Framework	IMF-001 — Information Management Framework
Document Owner	Data Protection Officer
Custodian	Legal / Compliance
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]
Regulatory Alignment	GDPR (EU) 2016/679, UK GDPR, CCPA/CPRA, HIPAA (45 CFR Parts 160 and 164)

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft — covers ROPA, DPIA, DSR, breach notification, and cross-border transfer processes
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This Standard Operating Procedure operationalises POL-004 (Privacy Policy). It defines the step-by-step procedures for: registering new processing activities in the Records of Processing Activities (ROPA), conducting Data Protection Impact Assessments (DPIAs), handling Data Subject Requests (DSRs) across all applicable rights, responding to personal data breaches within statutory timelines, and assessing cross-border data transfers.

Each process in this SOP is self-contained and can be triggered independently. All processes feed into the DPO's privacy governance obligations and may be requested as evidence during regulatory authority inspection or investigation.

IMPORTANT: Statutory deadlines in privacy law are hard. The 72-hour GDPR breach notification obligation and the 1-month DSR response deadline carry significant fines for non-compliance. This SOP is designed to ensure those deadlines are met systematically — not by heroic individual effort under pressure.

2. Scope

This SOP applies to all personal data processing activities within the scope of POL-004: all data subjects (employees, clinical trial participants, patients, customers, suppliers, website users), all processing activities where [Company Name] acts as Controller or Processor, and all personnel who process personal data.

3. Roles and Responsibilities

Role	Responsibility in This SOP
Data Protection Officer (DPO)	Owns this SOP. Owns and maintains the ROPA. Leads or oversees all DPIA processes. Coordinates all DSR responses. Leads breach assessment and regulatory notification. Approves cross-border transfer mechanisms. Independent statutory function — cannot be directed on how to perform these obligations.
Data Owner	Notifies DPO of new or changed processing activities before they commence. Provides input to DPIA. Processes DSRs within their data domain. Reports suspected breaches immediately.
Legal / Compliance	Drafts and reviews DPAs, BAAs, SCCs, and consent mechanisms. Advises on lawful bases and cross-border transfer mechanisms. Coordinates regulatory authority engagement. Reviews DSR responses for legal risk.

Role	Responsibility in This SOP
Information Security	Supports breach detection (POL-012). Provides technical input to DPIA risk assessments. Implements technical controls for Tier 4 personal data. Supports TIAs for cross-border transfers.
Data Custodian (IT)	Executes technical DSR operations (erasure, export, restriction, pseudonymisation). Implements deletion schedules per POL-002. Provides system configuration details for DPIA and TIA.
All Personnel	Report suspected breaches or DSRs immediately to the DPO. Process personal data only for documented purposes. Complete annual privacy training.

4. Process Trigger Events

Trigger	Process Initiated	Section
New processing activity proposed or commenced	ROPA Registration — register before processing begins	Section 5
New processing activity with potential high privacy risk	DPIA — conduct assessment before commencing	Section 6
Data subject contacts [Company Name] to exercise a right	DSR Handling — log, verify, respond within deadline	Section 7
Suspected or confirmed personal data breach	Breach Response — assess, notify, document	Section 8
New cross-border transfer of personal data proposed	Transfer Assessment — confirm mechanism, conduct TIA	Section 9
Annual calendar	Annual ROPA review — validate all entries, update, archive	Section 10

5. Process A — ROPA Registration

The Records of Processing Activities (ROPA) is the authoritative register of all personal data processing at [Company Name]. Every processing activity must be registered before it commences. The ROPA is a primary document for regulatory inspection under GDPR Article 30.

Step 01	**Identify New Processing Activity** Any Data Owner proposing a new processing activity involving personal data — including new systems, new data categories, new purposes, or material changes to existing processing — must notify the DPO before the activity commences. Common triggers for notification: • Procurement of a new system that will hold personal data • New HR initiative collecting employee data • New clinical trial or research programme • New marketing or customer engagement activity • Change of purpose for existing personal data • New third-party processor relationship	Responsible **Data Owner**
Step 02	**Complete ROPA Intake Form** The Data Owner, with DPO assistance, completes the ROPA Intake Form. The form captures: • Name and description of the processing activity • Controller / Processor status • Purpose of processing • Proposed lawful basis (Article 6) — and Article 9 condition if Special Category data • Categories of data subjects (employees, patients, trial participants, etc.) • Categories of personal data (name, health data, genetic data, etc.) • Special Category data? (yes/no) — if yes, triggers DPIA screening (Section 6) • Recipients of personal data (internal and external) • Cross-border transfers? (yes/no) — if yes, triggers Transfer Assessment (Section 9) • Proposed retention period (must align with POL-002) • Technical and organisational security measures in place or planned	Responsible **Data Owner / DPO**
Step 03	**DPO Review of Lawful Basis** The DPO reviews the proposed lawful basis. Key checks: • Is the proposed basis appropriate for the purpose and data subject category? • For employees: genuine consent is rarely achievable — is Legal Obligation or Contract more appropriate? • For clinical trial participants: has explicit consent been obtained per ICH E6(R2)? Is the ICF approved? • For Special Category data: is a valid Article 9 condition documented? • Is a Legitimate Interests Assessment (LIA) required? (Required where Article 6(1)(f) is proposed) If the proposed basis is not appropriate: DPO advises on the correct basis. Processing must not commence until the lawful basis is confirmed.	Responsible **DPO**
Step 04	**DPIA Screening** The DPO screens the processing activity for DPIA requirement (see Section 6 for full DPIA process). A DPIA is mandatory if the activity: • Involves large-scale Special Category data processing • Involves	Responsible **DPO**

	systematic profiling or automated decision-making with significant effects • Involves a new technology not previously assessed • Is identified as high risk in screening If a DPIA is required: complete the DPIA (Section 6) before registering the activity in the ROPA as 'Active'. The ROPA entry may be created as 'Pending DPIA' in the interim.	
Step 05	**Create ROPA Entry** The DPO creates or updates the ROPA entry with all information from the Intake Form and any additional details gathered during review. The ROPA entry is stamped with: • Date of creation • Processing activity status (Active / Pending DPIA / Historic) • DPIA reference (if applicable) • DPO review date and outcome • Next review date (annual or on material change, whichever comes first) The Data Owner receives a copy of the completed ROPA entry for their records.	Responsible **DPO**
Step 06	**Privacy Notice Update Check** The DPO confirms whether the new processing activity is covered by the current external-facing Privacy Notice and any relevant internal privacy notices (e.g., employee privacy notice). If not: the relevant notice must be updated before personal data is collected. Legal / Compliance drafts any required notice updates; DPO reviews and approves.	Responsible **DPO / Legal / Compliance**

6. Process B — Data Protection Impact Assessment (DPIA)

A DPIA identifies and mitigates privacy risks in new or significantly changed processing activities. It is mandatory for high-risk processing (GDPR Article 35) and must be completed before the processing commences. DPIAs are produced for regulatory inspection — they must be thorough and honest about residual risks.

6.1 DPIA Triggers (Mandatory)

- Large-scale processing of Special Category data — including all clinical trial participant health and genetic data
- Systematic profiling or automated decision-making with significant effects on individuals
- Large-scale processing of personal data from a publicly accessible area
- Deployment of new technology not previously assessed (AI/ML tools, wearables, biometric systems, tracking technologies)
- Any cross-border transfer to a country without an adequacy decision where TIA confirms residual risk is elevated
- Any processing activity identified as high risk during ROPA screening by the DPO

6.2 DPIA Process

Step 01	**Scope and Describe the Processing** The DPO and Data Owner define and document: • The nature, scope, context, and purpose of the processing • The categories and volume of data subjects and personal data • The systems, processors, and data flows involved • The necessity and proportionality of the processing — is it the minimum required to achieve the purpose? This forms the description section of the DPIA template. Use plain language — DPIAs may be provided to supervisory authorities.	Responsible **DPO / Data Owner**
Step 02	**Consult Stakeholders** The DPO identifies and consults relevant stakeholders as part of the DPIA: • Data subjects or their representatives (where feasible) — particularly for employee monitoring or clinical trial participant data • Information Security — for technical risk assessment • Legal / Compliance — for regulatory obligation review • System Owner / IT — for technical architecture and control assessment • Processors (third parties) — where the processing involves a new processor relationship Consultation evidence is documented in the DPIA.	Responsible **DPO**
Step	**Identify and Assess Privacy Risks**	Responsible **DPO /**

03	For each component of the processing activity, identify risks to data subjects: Assess likelihood (1–5) and severity (1–5) of harm to data subjects from: • Unauthorised access to personal data • Data loss or corruption • Purpose creep (use of data beyond stated purpose) • Excessive data collection • Inaccurate data leading to adverse decisions • Inability of data subjects to exercise their rights • Discrimination or reputational harm resulting from data processing Risk score = Likelihood × Severity • High (15–25): must be mitigated before processing commences • Medium (8–14): must be mitigated; DPIA may proceed to approval with mitigating measures committed • Low (1–7): document and monitor	**Information Security**
Step 04	**Define and Document Mitigating Measures** For each High and Medium risk, document the technical and organisational measures to mitigate it: • Technical: encryption, pseudonymisation, access controls, data minimisation in system design, automated deletion • Organisational: training, DPAs with processors, access restriction policies, audit trail review • Legal: updated privacy notices, consent mechanisms, DPA provisions For each measure: describe it, assign an owner, set a completion date, and confirm how its effectiveness will be verified. After mitigating measures are applied, re-rate the residual risk.	Responsible **DPO / Data Owner / Information Security**
Step 05	**Supervisory Authority Consultation (if required)** If residual risk remains High after all feasible mitigating measures have been applied, [Company Name] must consult the relevant supervisory authority before commencing processing (GDPR Article 36). The DPO prepares the consultation submission: • DPIA document (full) • Description of the processing and the unmitigated high risk • Measures already taken • Contact details of DPO and controller The supervisory authority has 8 weeks to respond (extendable to 14 weeks). Processing must not commence until the authority responds or the consultation period expires without objection.	Responsible **DPO / Legal / Compliance**
Step 06	**DPO Approval and Filing** The DPO reviews the completed DPIA — including all risk assessments and mitigating measures — and approves it if satisfied that risks are adequately addressed. If the DPO does not approve: • The processing must not commence • The Data Owner and DPO agree on additional measures or an alternative approach Approved DPIAs are filed in the privacy management system and linked to the ROPA entry. The DPIA reference number is recorded in the ROPA. The DPIA review date is set at 3 years from approval or on material change.	Responsible **DPO**

7. Process C — Data Subject Request (DSR) Handling

Data subjects may exercise their privacy rights at any time. All such requests must be logged and responded to within the statutory deadline regardless of how they are received — whether by email, letter, phone, social media, or in person.

7.1 Statutory Response Deadlines

Right	GDPR / UK GDPR Deadline	CCPA Deadline	HIPAA Deadline
Right of Access	1 month (extendable to 3 months)	45 days (extendable to 90)	30 days (extendable to 60)
Right to Rectification	1 month	45 days	60 days
Right to Erasure	1 month	45 days	N/A (amendment only)
Right to Restriction	Implement promptly on receipt	N/A	N/A
Right to Portability	1 month	45 days	N/A
Right to Object	Immediately for direct marketing	Immediately for opt-out	N/A
Withdraw Consent	Effect immediately	N/A	N/A
HIPAA Access / Amendment	N/A	N/A	30 days (extendable to 60)

7.2 DSR Process

Step 01	**Receive and Log the Request** DSRs may be received by any team member or via any channel. Upon receipt: • Forward to the DPO immediately (same business day) • Do not respond substantively to the data subject until the DPO has reviewed the request — even an apparently simple 'yes we hold your data' response triggers legal obligations The DPO logs the DSR in the DSR Register within 1 business day of receipt: • Date received (the response clock starts from this date) • Data subject name and contact details • Right being exercised • Description of the request • Deadline date • Assigned handler	Responsible **All Personnel (receipt) / DPO (log)**
Step 02	**Verify Identity** Before responding to any DSR, the identity of the requestor must be verified to confirm they are the data subject (or an authorised representative). Identity verification must be proportionate to the	Responsible **DPO**

	sensitivity of the data: Low-sensitivity data (e.g., general contact data): confirmation of name and one other identifier (e.g., email address on file) High-sensitivity data (Tier 4, health data, PHI): confirmation of name plus two additional identifiers, or a copy of a government-issued ID For employee DSRs: HR system verification is sufficient. For clinical trial participant DSRs: verify against the trial subject register using the pseudonymised subject ID — contact Compliance / QA for the re-identification key. Do not request excessive information for verification — this itself can be a GDPR breach. The verification response time counts against the response deadline.	
Step 03	**Assess the Request** The DPO assesses the request: • Is the right claimed applicable to [Company Name] for this data? (e.g., portability only applies where the lawful basis is consent or contract) • Are there any exemptions or limitations that apply? (e.g., the right to erasure does not apply to GxP records within their retention period; access requests can be refused for manifestly unfounded requests) • Does fulfilling the request require input from multiple Data Owners or systems? • Does the request affect third parties (e.g., a request to access correspondence that includes other individuals' data)? For CCPA requests: confirm the individual is a California consumer and that [Company Name] meets CCPA thresholds. For HIPAA requests: engage the Privacy Officer for PHI access or amendment requests.	Responsible **DPO / Legal / Compliance**
Step 04	**Search and Compile Responsive Data** The DPO coordinates the data search across all relevant systems and Data Owners: • Issue search instructions to each Data Owner with the data subject's identifiers and a list of systems to search • Data Owners and Data Custodians (IT) execute system searches and return results to the DPO within 10 business days of receiving instructions • The DPO reviews the results: redact any third-party personal data; confirm no information should be withheld on legal grounds; confirm the response is complete For Subject Access Requests: compile the data in a structured, commonly used, machine-readable format where possible (e.g., CSV, PDF).	Responsible **DPO / Data Owner / Data Custodian (IT)**
Step 05	**Respond to Data Subject** The DPO prepares and sends the response to the data subject: • Use plain, clear language — not legal jargon • Confirm the action taken (data provided, data erased, processing restricted, etc.) • If a limitation or exemption applies: explain why the right cannot be fully exercised • If an extension is required (GDPR: month 1 → month 3): notify the data subject within the original 1-month deadline, explaining the reason for the extension • For access requests: provide the data in the requested format where feasible For CCPA opt-out of sale: implement the opt-out technically within 15 business days of the verified request. For HIPAA access: provide PHI in the format requested where feasible (paper or electronic). The DPO logs the response date, format, and outcome in the	Responsible **DPO**

	DSR Register.	
Step 06	**Implement Technical Action (where required)** Where the DSR requires a technical action — erasure, restriction, portability export, correction — the Data Custodian (IT) executes the technical operation within 5 business days of the DPO's instruction: • Erasure: delete the data from all systems including backups (note: GxP records within retention period cannot be erased — inform data subject of the exemption) • Restriction: flag the record in all relevant systems to prevent further processing; confirm restriction is in place • Portability: export the data in the requested format; confirm completeness • Rectification: update the record in all relevant systems; notify all recipients of the original inaccurate data The Data Custodian (IT) confirms completion to the DPO in writing.	Responsible **Data Custodian (IT)**
Step 07	**Close and Retain Record** The DPO updates the DSR Register with the closure date and outcome. DSR records are retained for 3 years from the date of closure per POL-002 Section 5.5. The DPO reviews DSR trends quarterly — patterns in DSR types may indicate that privacy notices, consent mechanisms, or data practices need updating.	Responsible **DPO**

8. Process D — Personal Data Breach Response

A personal data breach is any security incident that results in accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to personal data. The 72-hour GDPR supervisory authority notification clock starts from when [Company Name] becomes aware — not when the breach is confirmed.

> **GxP:** When in doubt about whether an incident constitutes a personal data breach, treat it as one and follow this process. It is better to assess and determine no notification is required than to miss the 72-hour deadline. Document all assessments and decisions thoroughly.

Timeline	Obligation	Owner
T+0 — immediate	Incident discovered. Report to DPO and Information Security immediately. Activate POL-012 Incident Response simultaneously.	All Personnel
T+1 hour	DPO + CISO acknowledge and begin breach assessment. Preserve evidence. Identify Data Owners.	DPO / CISO
T+4 hours	Initial scope confirmed: categories and approximate volume of personal data affected identified.	DPO / Data Owner
T+24 hours	DPO completes initial breach assessment form: nature of breach, data affected, likely consequences, measures taken or planned.	DPO
T+48 hours	Legal / Compliance confirms whether notification to supervisory authority is required. If likely: begin preparing notification.	DPO / Legal
T+72 hours (GDPR deadline)	If notification is required: submit to supervisory authority. If notification is not required: document the decision with reasoning.	DPO
Without undue delay (GDPR Art. 34)	If breach likely results in high risk to data subjects: notify affected individuals in plain language.	DPO / Legal / Communications
HIPAA: T+60 days (from discovery)	Notify HHS Secretary. If >500 individuals in a state: notify media.	Privacy Officer / Legal
Post-breach	Root cause analysis. CAPA. Update breach register. Annual breach summary to ISSG.	DPO / Information Security

8.1 Breach Assessment

Step 01	**Activate Breach Response** Upon any report of a suspected breach involving personal data: • DPO is notified immediately and takes ownership of the privacy response • Information Security activates POL-012 (Incident Response Policy) simultaneously — the technical and privacy responses run in parallel • A Breach Reference Number is assigned (BR-YYYY-NNN) • The DPO notifies all Data Owners whose data may be affected • Legal / Compliance is notified	Responsible **DPO / CISO**
Step 02	**Contain and Preserve** The DPO and Information Security coordinate containment: • Isolate affected systems or data to prevent further exposure (technical containment per POL-012) • Preserve evidence of the breach — do not delete or modify any data or logs related to the incident • Identify whether data has been exfiltrated, lost, or disclosed — and to whom • Confirm whether personal data of clinical trial participants, patients, or employees is involved (triggers highest priority response)	Responsible **DPO / Information Security**
Step 03	**Assess Notification Requirement** The DPO, with Legal / Compliance input, assesses whether GDPR Article 33 notification to the supervisory authority is required. Notification is required if the breach is 'likely to result in a risk to the rights and freedoms of natural persons'. Factors indicating notification IS required: • Any disclosure of Special Category data (health, genetic, biometric data) to unauthorised parties • Any loss of clinical trial participant or patient data • Large volume of data subjects affected (generally >250 individuals) • Data disclosed to a party who could use it to harm the data subject • Ransomware encrypting personal data (unless backup is unaffected) Factors indicating notification may NOT be required: • Data was encrypted and the key was not compromised • Very small number of data subjects affected with no Special Category data • Data was immediately recovered with no evidence of access Document the assessment and its conclusion regardless of outcome.	Responsible **DPO / Legal / Compliance**
Step 04	**Submit Supervisory Authority Notification** If notification is required, the DPO submits to the relevant supervisory authority within 72 hours of becoming aware. The notification must include (GDPR Article 33(3)): • Nature of the breach (categories and approximate number of records and data subjects) • Contact details of the DPO • Likely consequences of the breach • Measures taken or proposed to address the breach and mitigate its effects If all information is not available within 72 hours: submit what is known and provide supplementary notification as additional information becomes available. Document the submission reference number. For UK GDPR: notify the ICO. For EU GDPR: notify the lead supervisory authority (determined by [Company Name]'s EU establishment). For HIPAA: notify HHS Secretary within 60 days.	Responsible **DPO / Legal / Compliance**

Step 05	**Data Subject Notification (if required)** If the breach is likely to result in a high risk to the rights and freedoms of data subjects (GDPR Article 34), the affected individuals must be notified without undue delay. The notification must: • Be in clear, plain language — no legal jargon • Describe the nature of the breach in terms the individual will understand • Provide the DPO's contact details • Describe the likely consequences of the breach • Describe the measures [Company Name] has taken or plans to take to address the breach • Advise the individual of practical steps they can take to protect themselves For large-scale breaches: coordinate with Communications / PR. For employee data: engage HR. Document every data subject notified — date, method, content.	Responsible **DPO / Legal / Communications**

Step 06	**Document and Close** The DPO completes the Breach Register entry: • All notification decisions and their rationale • Submission references for supervisory authority notifications • List of data subjects notified • Root cause (preliminary) • CAPA reference The breach remains open until the CAPA is closed. The DPO reports all breaches (including those that did not require notification) to ISSG at the next quarterly meeting. Breach records are retained for 5 years per POL-002 Section 5.5.	Responsible **DPO**

9. Process E — Cross-Border Transfer Assessment

Before personal data is transferred outside the EEA (or from the UK, or from other jurisdictions with transfer restrictions), a valid transfer mechanism must be confirmed and — where required — a Transfer Impact Assessment (TIA) must be conducted.

Step 01	**Identify the Transfer** The Data Owner or DPO identifies a new or changed cross-border transfer of personal data. A 'transfer' includes: • Sending data to a processor or sub-processor in another country • Giving access to personal data to staff in another country • Routing data through systems hosted in another country • Cloud services where data may be stored or accessed outside the EEA/UK The Data Owner notifies the DPO and completes the Transfer Notification Form.	Responsible **Data Owner / DPO**
Step 02	**Check Adequacy Decision** The DPO checks whether the destination country has a current adequacy decision from the European Commission (EU GDPR) or UK Secretary of State (UK GDPR). If adequacy applies: the transfer may proceed (no additional mechanism required). Record in ROPA. Adequacy decisions must be re-confirmed annually — decisions can be revoked. If no adequacy decision: proceed to Step 3.	Responsible **DPO**
Step 03	**Select Transfer Mechanism** Where no adequacy decision applies, select the appropriate transfer mechanism: Standard Contractual Clauses (SCCs): EU Commission-approved clauses incorporated into the transfer contract. Require a TIA (Step 4). Most common mechanism for transfers to the US and other non-adequate countries. UK International Data Transfer Agreement (IDTA): UK equivalent of SCCs for transfers from the UK post-Brexit. Binding Corporate Rules (BCRs): For intra-group transfers — requires prior supervisory authority approval. DPO to confirm BCR status and scope. Derogations (Article 49): Last resort only. DPO must confirm no other mechanism is available. Explicit consent from data subjects required where consent is the basis — not feasible for large-scale processing. Legal / Compliance implements the chosen mechanism. SCCs and IDTAs are incorporated into the DPA or transfer agreement.	Responsible **DPO / Legal / Compliance**
Step 04	**Conduct Transfer Impact Assessment (TIA)** A TIA is required for all transfers using SCCs or IDTA — it assesses whether the destination country's legal framework undermines the protection the SCCs are designed to provide. The TIA must assess: • The destination country's surveillance laws — do they require disclosure of data to government authorities beyond what GDPR permits? • The effectiveness of the SCCs in practice — are there documented cases of data subjects being unable to exercise their rights? • Whether	Responsible **DPO / Legal / Compliance**

	supplementary measures are required (e.g., additional encryption, pseudonymisation, contractual obligations on the importer to challenge unlawful access demands) The TIA is documented and approved by the DPO. Where the TIA concludes that SCCs are not effective without supplementary measures: those measures must be implemented before the transfer commences. If the TIA concludes the transfer cannot be protected adequately: the transfer must not proceed. Escalate to CISO and Legal.	
Step 05	**Implement and Record** Legal / Compliance ensures the transfer mechanism is legally implemented (SCCs signed, IDTA executed, BCR scope confirmed). The DPO records the transfer in the ROPA: • Transfer destination and recipient • Transfer mechanism used • TIA reference number and conclusion • Date implemented • Next review date (annual) Transfer arrangements are reviewed annually and whenever the legal or technical landscape of the destination country changes materially.	Responsible **DPO / Legal / Compliance**

10. Process F — Annual ROPA Review

The ROPA must be reviewed and updated at least annually. The DPO coordinates the review in the fourth quarter of each calendar year to ensure the ROPA is current before any regulatory authority inspection cycle.

Step	Action	Responsible
1	DPO issues review instructions to all Data Owners: review ROPA entries in your domain and confirm accuracy, completeness, and continued necessity.	DPO
2	Data Owners review their entries within 30 days. Confirm: data is still processed as described; retention periods are still correct; recipients and processors are still engaged; lawful basis has not changed.	Data Owners
3	DPO reviews all Data Owner confirmations. Updates entries where changes are identified. Archives entries for processing activities that have ceased.	DPO
4	DPO checks for any new processing activities identified during the year that were not registered — creates entries retrospectively and assesses whether a DPIA should have been conducted.	DPO
5	DPO reviews adequacy decisions and TIAs for all cross-border transfers — confirms still current.	DPO
6	Updated ROPA is version-stamped and filed. Previous version is archived. DPO reports ROPA status to ISSG.	DPO

11. Records Generated by This SOP

Record	Storage Location	Retention Period	Responsible
ROPA (all versions)	Privacy management system	Duration of processing + 3 years (per POL-002)	DPO
DPIA records	Privacy management system	3 years post-processing cessation	DPO
DSR Register entries	Privacy management system	3 years from DSR closure date	DPO
Breach Register entries	Privacy management system	5 years from breach date (per POL-002)	DPO
Breach notification submissions	Privacy management system	5 years from breach date	DPO
TIA records	Privacy management system	Duration of transfer + 3 years	DPO
Supervisory authority correspondence	Privacy management system	7 years from correspondence date	DPO / Legal
ROPA Intake Forms	Privacy management system	Duration of processing + 3 years	DPO

12. Related Documents

Document ID	Title	Relationship
POL-004	Privacy Policy	Parent policy — requirements this SOP operationalises
POL-001	Data Classification Policy	Tier 4 (Sensitive Personal) classification triggers DPO consultation and DPIA screening
POL-002	Data Retention and Disposal Policy	Retention periods for all ROPA categories; GDPR data minimisation governs maximum retention
POL-003	Data Integrity Policy	GxP clinical trial participant data: ALCOA+ and audit trail requirements apply in parallel with privacy obligations
POL-005	System Classification Policy	Systems holding Tier 4 personal data classified minimum Tier 2 — informs DPIA technical

Document ID	Title	Relationship
		measures
POL-008	Access Control Policy	Access controls for Tier 4 and Special Category data systems
POL-010	Information Security Risk Policy	DPIA is the privacy domain-specific instance of the IS risk framework; DPIA High risks that cannot be mitigated feed into the organisation-wide Risk Register as Regulatory Compliance risks; DPO and CISO co-own privacy-related Risk Register entries
POL-012	Incident Response Policy	Breach detection and response — POL-012 and Section 8 of this SOP run in parallel for breaches involving personal data
POL-013	Third Party and Vendor Risk Policy	Processor assessment; DPA and BAA requirements for third parties processing personal data
SOP-001	Data Classification Process	Tier 4 classification at SOP-001 Step 4 triggers DPO notification and ROPA registration
SOP-002	Data Retention and Disposal Process	Disposal of personal data per POL-002 — GDPR data minimisation governs maximum retention periods
RACI-001	Roles, Responsibilities and Authorities	Privacy domain accountability mapping

— End of Document —

SOP-004 v1.0 DRAFT | [Company Name] | CONFIDENTIAL